Web Application Reconnaissance

Akintunde Ridwan Oladimeji
Student ID : 2025/INT/11578

Course Name : INT302 Kali Linux Tools and System Security

Instructor Name : Mr Aminu Idris (AMCPN)

Date of Submission : 27/12/2025
Version : 1.0

Table of Contents

1.0 Introduction
2.0 Aim and Objectives
2.1 The objective of this lab includes
2.2 Tools
3.0 Methodology
3.1 Part one : IP Address of Domain, WHOIS, DNS Lookup
3.1.1 Icdfa.edu.ng
3.1.2 Nasarawa.gov.ng
3.1.3 Icdfa.org.ng
3.2 Part Two : Technology Fingerprint with WhatWeb
3.3 Part Three : Website Enumeration and Information Gathering
3.4 Part Four : Subdomain Enumeration and Tool Comparison
3.4.1 Sublist3r
3.4.2 KnockPy
3.5 Part 5 : Directory Enumeration with Dirb
3.6 Part 6 : Basic Port Scanning and vulnerability Detection
3.7 Part 7 : Bash scripting for Simple reconnaissance Tool
3.8 Part 8
3.8.1 Post Request
3.8.2 Get Request
3.8.3 A quick case study
3.9 Part 9 : Information Gathering in Web Application Security
3.10 Part 10
3.10.1 How Websites works (request-response model, DNS role)
3.10.2 Domain Name System (DNS)
3.10.3 DNS server
4.0 Analysis and Findings
4.1 Results
4.2 Differences
5.0 Conclusion and Recommendations

1.0 Introduction

Web application reconnaissance is the initial phase of web application security testing that involves systematically gathering information about a target application to understand its structure, technologies, and potential attack surface (Engebretson, 2013). This phase aims to identify key components such as domains, subdomains, server configurations, frameworks, and accessible endpoints without exploiting any vulnerabilities. Effective reconnaissance allows security professionals to map the application environment and prioritize areas that may present security risks (Stuttard & Pinto, 2011).

Reconnaissance activities are commonly divided into passive and active techniques. Passive reconnaissance focuses on collecting information from publicly available sources without direct interaction with the target system, thereby minimizing detection (OWASP Foundation, 2023). Active reconnaissance involves controlled interaction with the web application, including directory enumeration, parameter discovery, and analysis of HTTP requests and responses. The information gathered during this phase forms the foundation for vulnerability assessment and penetration testing, making reconnaissance a critical component of web application security assessments (Behl & Behl, 2017).

2.0 Aim and Objectives

The aim of this lab is to gain hands-on experience on web application information gathering, analyze the information for clear and concise patterns for exploitable information.

2.1 The objective of this lab includes

- Carrying out basic and advanced reconnaissance on icdfa.edu.ng, icdfa.org.ng, nasarawastate.gov.ng,OWASP-BWA manchine.
- analyzing the types of request used in web applications
- Elaborating the dns operations in web application

2.2 Tools

- Whatweb
- Sublist3r
- KnockPy
- Dirb
- Nmap
- Nikto
- MySQL client
- Multillidae (running on OWASP BWA)

3.0 Methodology

3.1 Part one : IP Address of Domain, WHOIS, DNS Lookup

3.1.1 Icdfa.edu.ng

- Opened the linux terminal and ran the following command for the target icfda.edu.ng
- *whois icdfa.edu.ng*
- *Ping -c 4 icdfa..edu.ng*
- *Nslookup -type=A icdfa.edu.ng*
- *Nslookup -type=MX icdfa.edu.ng*
- *Nslookup -type=NS icdfa.edu.ng*
- *Dig nasarawastate.gov.ng Any*
- The command returns basic information about the target domain

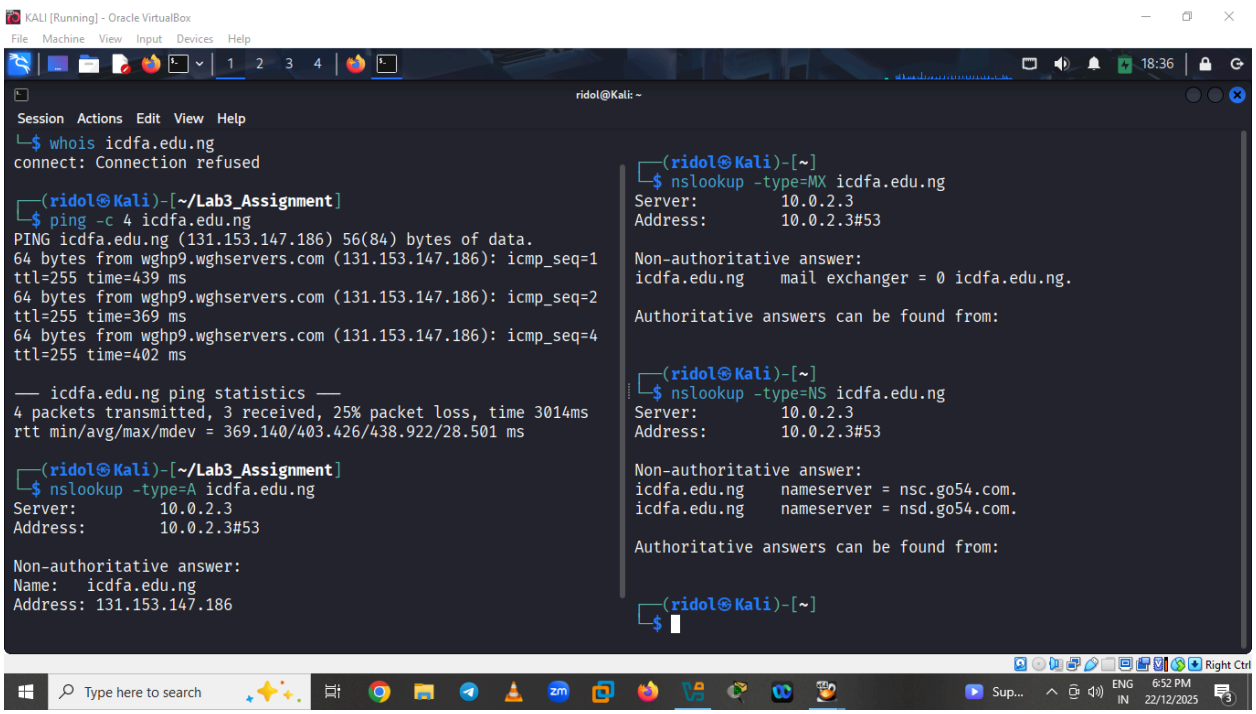

Fig 1: Evidence of linux terminal showing the results for the target icdfa.edu.ng

3.1.2 Nasarawa.gov.ng

- Opened the linux terminal and ran the following command for the target nasarawa.gov.ng

- *whois icdfa.edu.ng*
- *Ping -c 4 nasarawa.gov.ng*
- *Nslookup -type=A nasarawa.gov.ng*
- *Nslookup -type=MX nasarawa.gov.ng*
- *Nslookup -type=NS nasarawa.gov.ng*
- *Dig nasarawastate.gov.ng Any*
- The command returns basic information about the target domain

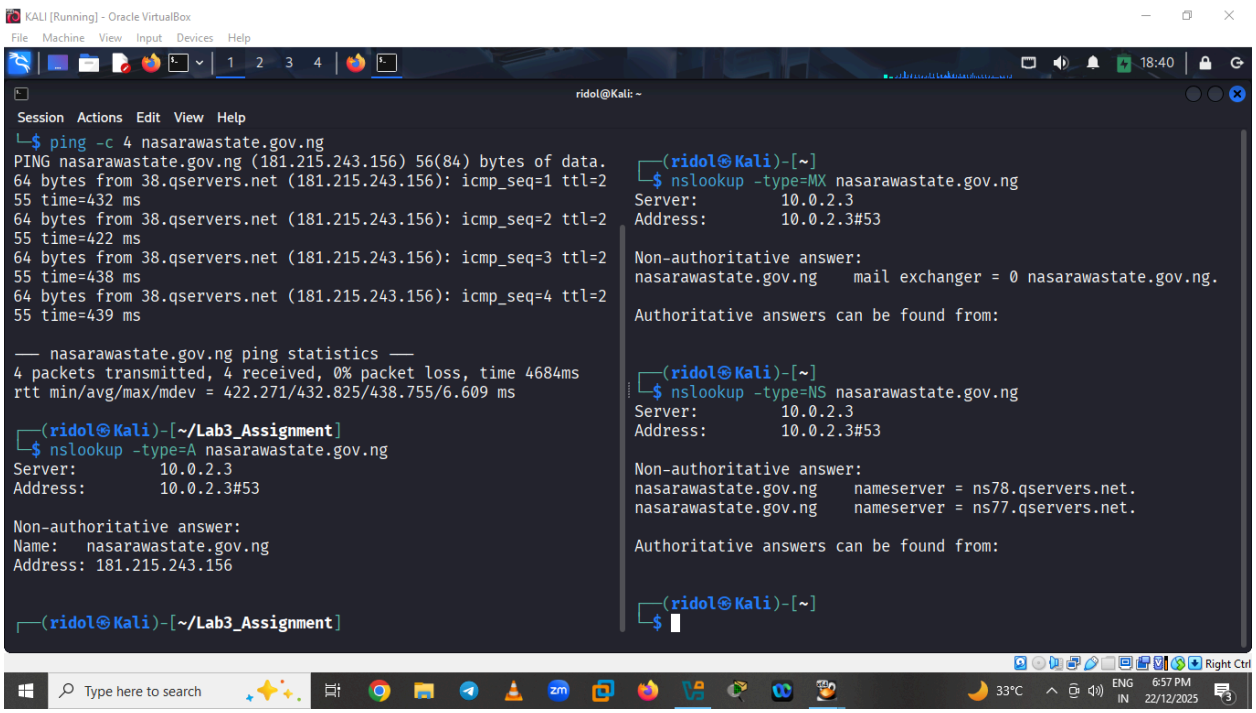

Fig 2: Evidence of linux terminal showing the results for the target nasarawastate.gov.ng

3.1.3 Icdfa.org.ng

- Opened the linux terminal and ran the following command for the target icfda.org.ng
- *whois icdfa.org.ng*
- *Ping -c 4 icdfa.org.ng*
- *Nslookup -type=A icdfa.org.ng*
- *Nslookup -type=MX icdfa.org.ng*
- *Nslookup -type=NS icdfa.org.ng*

- *Dig icdfa.org.ng Any*
- The command returns basic information about the target domain

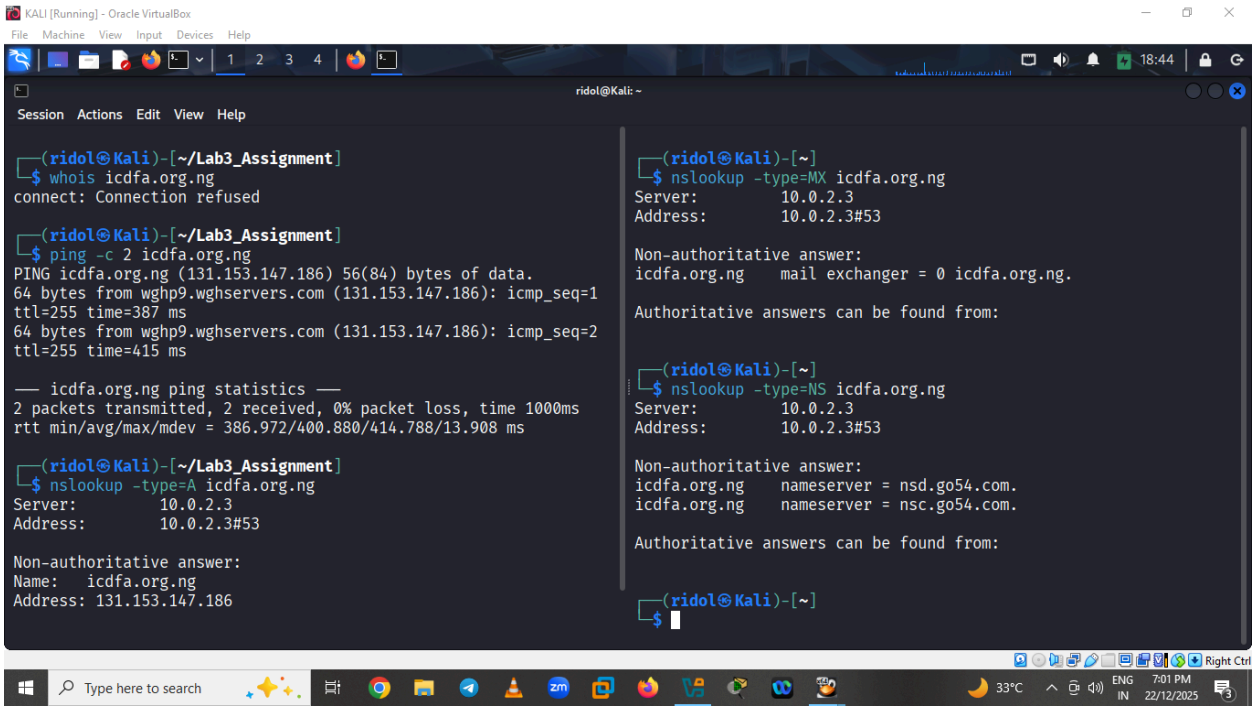

Fig 3: Evidence of linux terminal showing the results for the target icdfa.org.ng

3.2 Part Two : Technology Fingerprint with WhatWeb

Target : OWASP BWA machine

- Opened the linux terminal and ran the following command for the target **http://192.168.56.101**
- whatweb http://192.168.56.101 for basic scan
- whatweb -a 3 -v http://192.168.56.101 for aggressive scan in a verbose mode
- The basic scan returns confidential information about the target such as server types, administrative credentials, IP address
- The aggressive scan in a verbose mode returns a well structured information in details than the basic scan

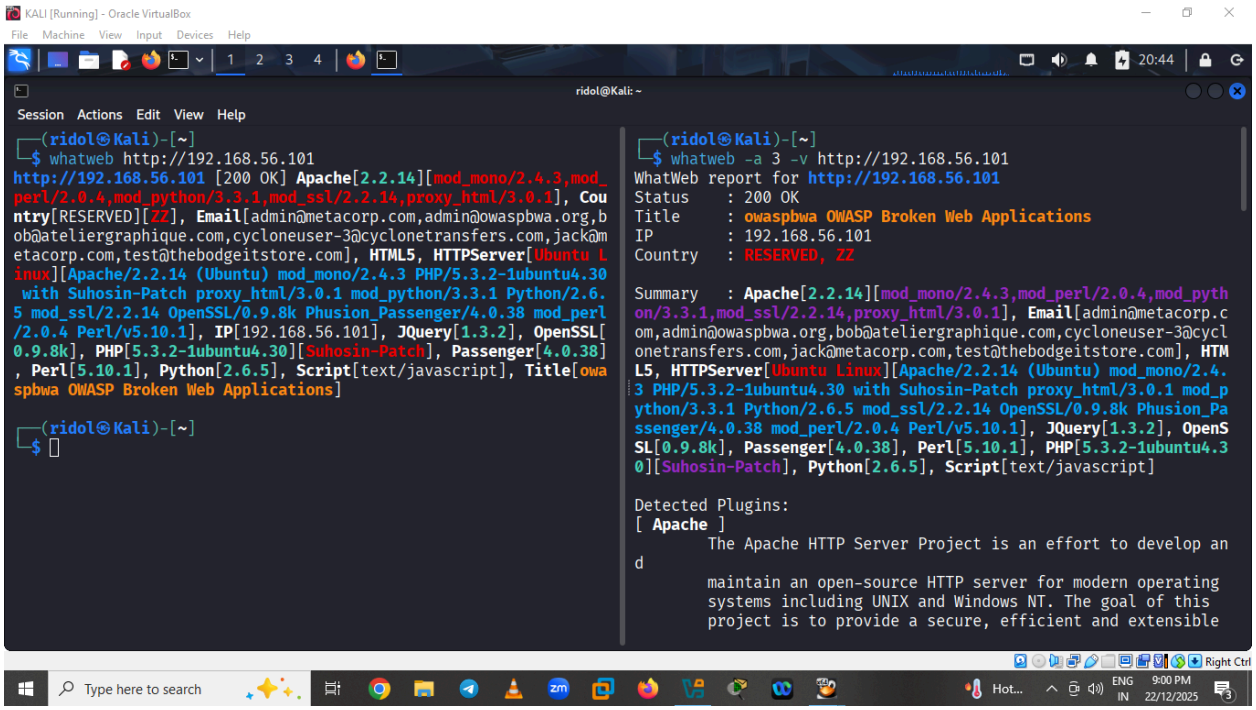

Fig 4: Evidence of linux terminal showing the results for the target http://192.168.56.101

3.3 Part Three : Website Enumeration and Information Gathering

- Opened the linux terminal and ran the following command for the target **http://192.168.56.101**
- Curl -I http://192.168.56.101
- The command reveals the HTTP headers information such as the server (apache/2.2.12) , framework (php)

Fig 5: Evidence of linux terminal showing the results for the target http://192.168.56.101

3.4 Part Four : Subdomain Enumeration and Tool Comparison

3.4.1 Sublist3r

- Opened the linux terminal and ran the following command for the target icfda.edu.ng, nasarawastate.gov.ng, icdfa.org.ng
- Ran the command Sublist3r -d icdfa.edu.ng > icdfa1_sublist3r.txt
- Ran the command Sublist3r -d nasarawastate > nasarawastate_sublist3r.txt
- Ran the command Sublist3r -d icdfa.org.ng > icdfa2_sublist3r.txt
- The command search for the subdomains of the target website and save the result to the .txt file

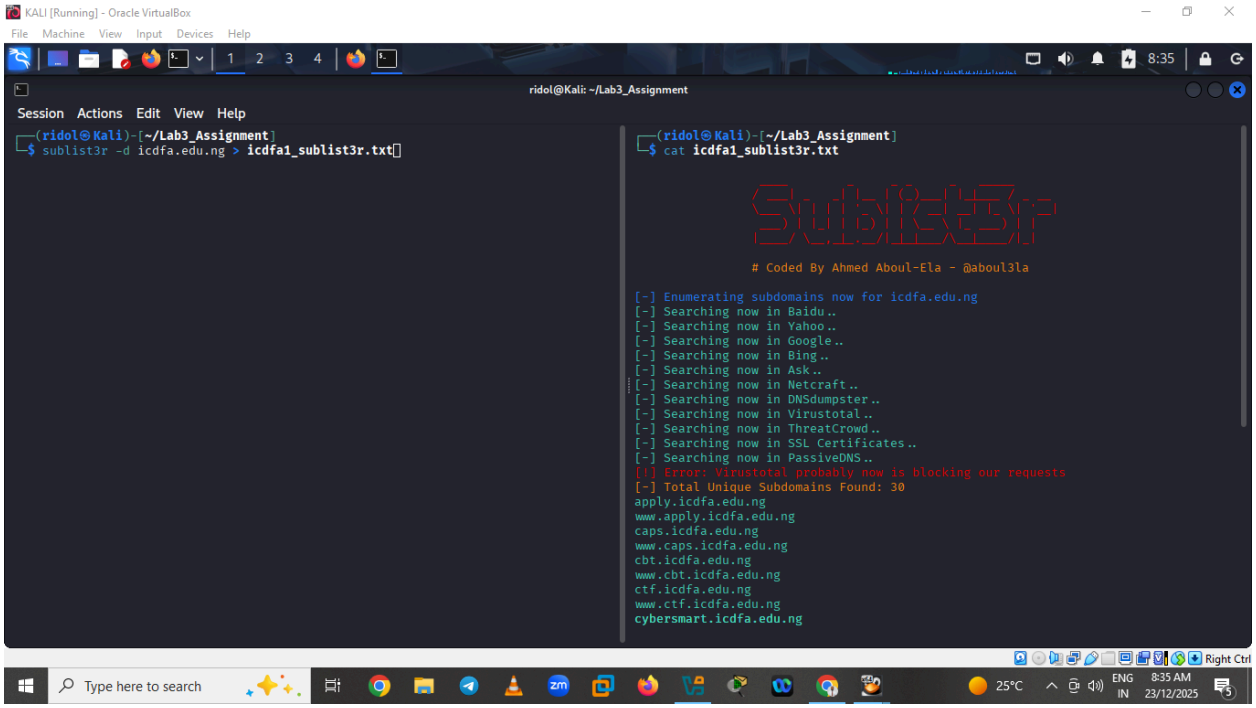

Fig 6: Evidence of linux terminal showing the sublist3r results for the target icdfa.edu.ng

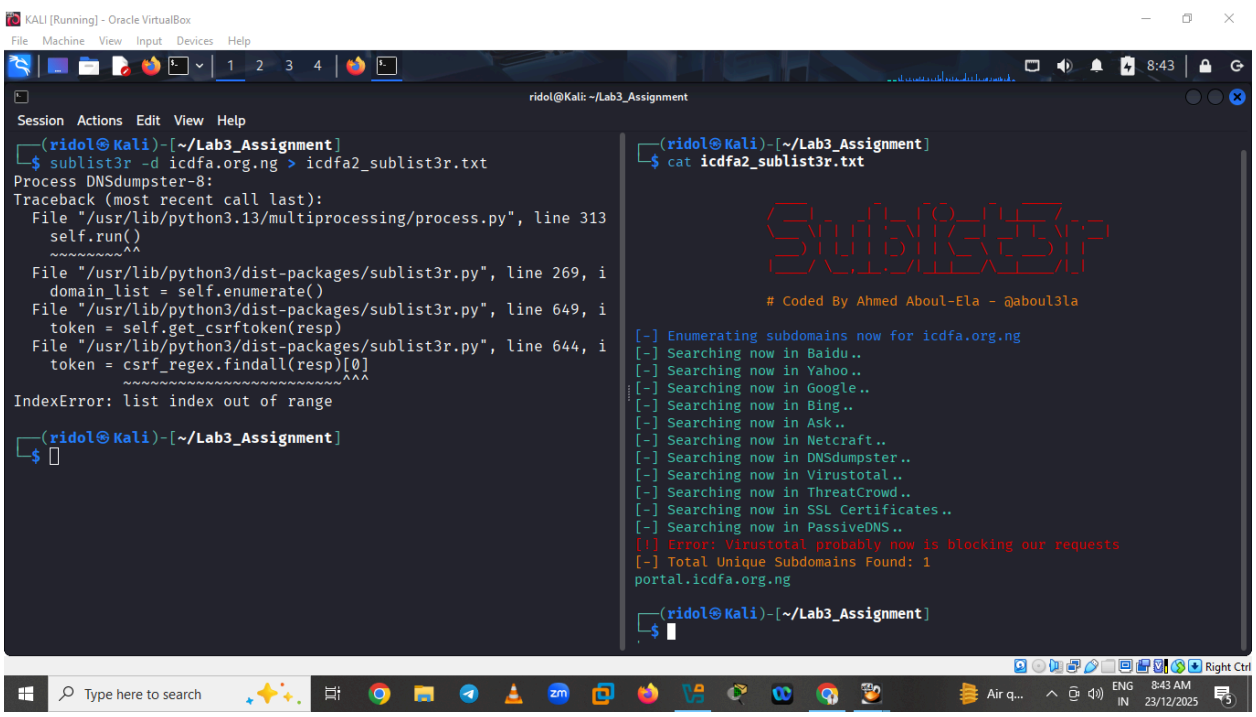

Fig 7: Evidence of linux terminal showing the sublist3r results for the target icdfa.org.ng

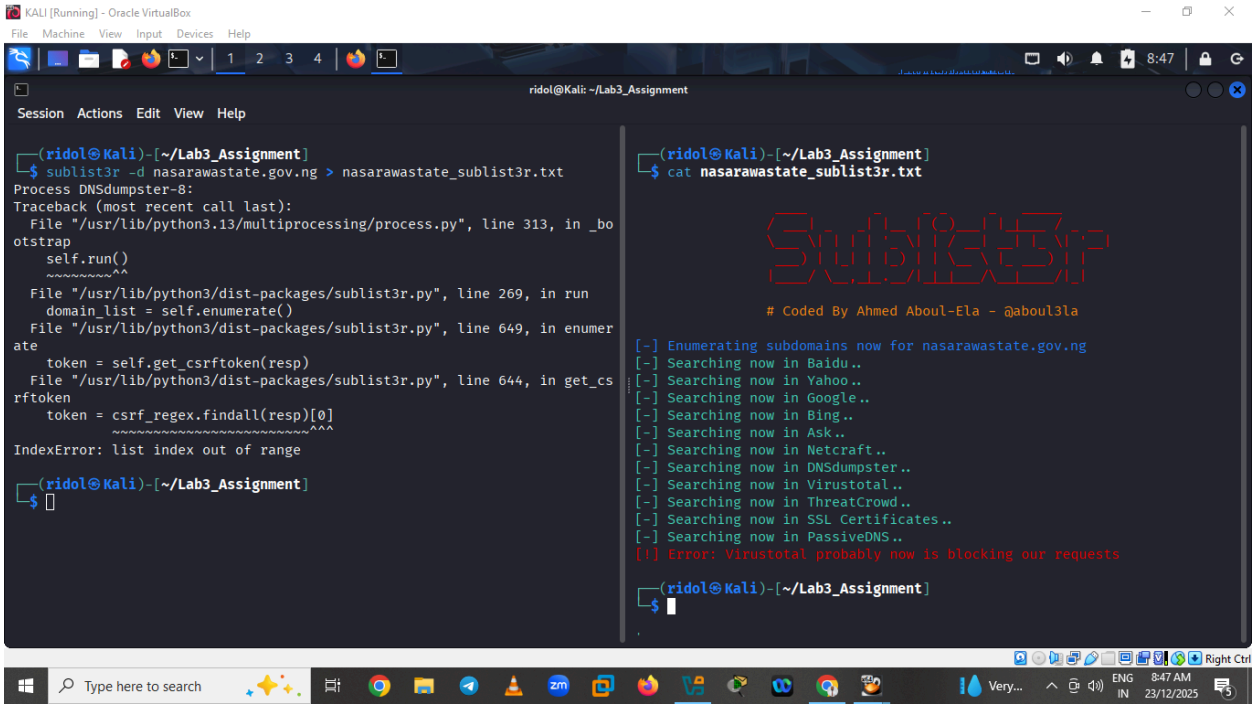

Fig 8: Evidence of linux terminal showing the sublist3r results for the target nasarawastate .gov.ng

3.4.2 KnockPy

- Opened the linux terminal and ran the following command for the target icfda.edu.ng, nasarawastate.gov.ng, icdfa.org.ng
- Ran the command knockpy -d icdfa.edu.ng -- recon > icdfa1_knockpy.txt
- Ran the command knockpy -d nasarawastate -- recon > nasarawastate_knockpy.txt
- Ran the command knockpy -d icdfa.org.ng -- recon > icdfa2_knockpy.txt
- The command search for the subdomains of the target website and save the result to the .txt file

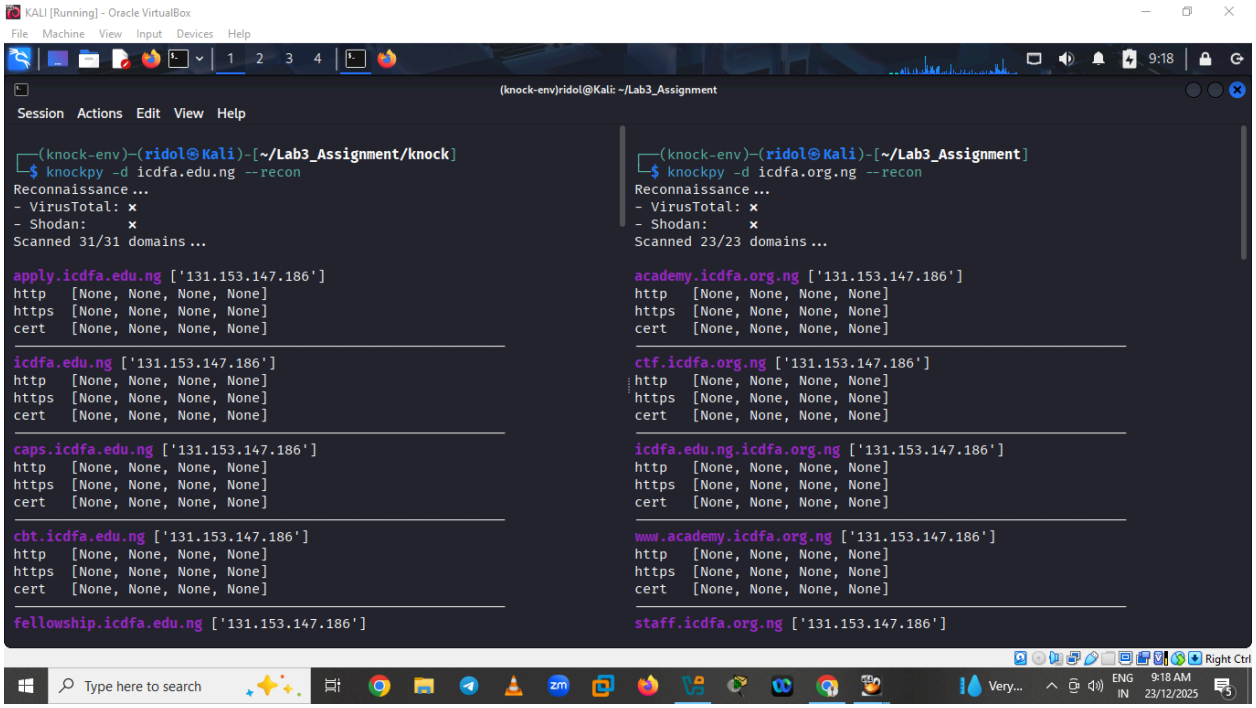

Fig 9: Evidence of linux terminal showing the knockpy results for the target icdfa.edu.ng and icdfa.org.ng

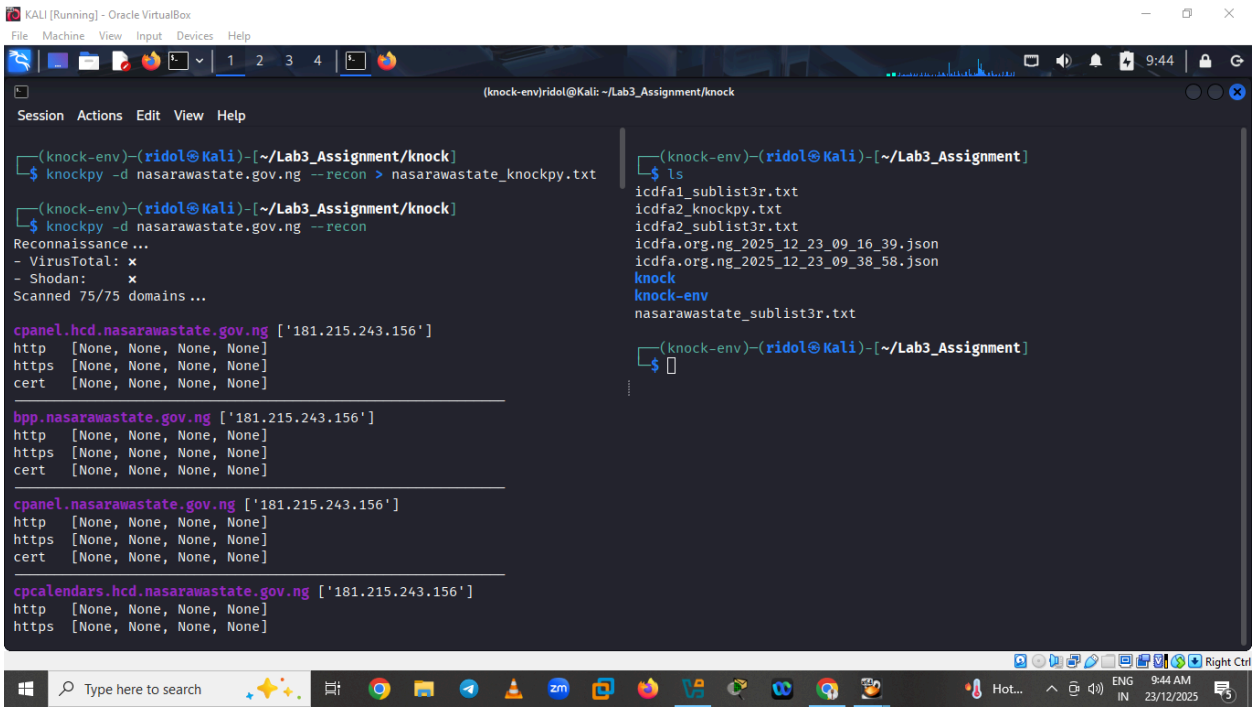

Fig 10: Evidence of linux terminal showing the knockpy results for the target nasarawastate .gov.ng

3.5 Part 5 : Directory Enumeration with Dirb

Target : OWASP BWA machine

- Opened the linux terminal and ran the following command for the target **http://192.168.56.101**
- dirb http://192.168.56.101/
- the command performed a brute force for subdomain using the target IP address again several combinations of wordlists by default for OWASP BWA machine.

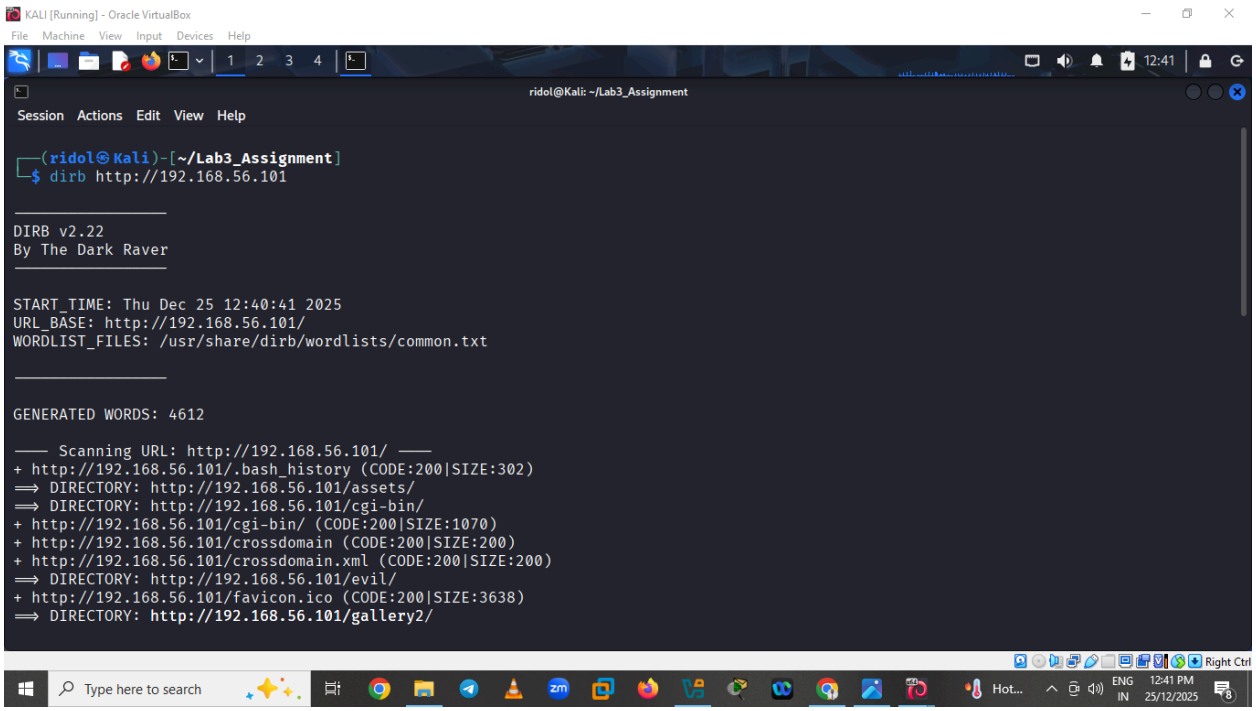

Fig 11: Evidence of linux terminal showing the dirb results for the target http://192.168.56.101

3.6 Part 6 : Basic Port Scanning and vulnerability Detection

Target : OWASP BWA machine

- Opened the linux terminal and ran the following command for the target **http://192.168.56.101**

- nmap http://192.168.56.101 for port scanning
- nikto -h 192.168.56.101 - Tuning 123 -o nikto_result.txt
- Cat nikto_result.txt
- The port scanning results revealed open tcp ports such as 22-ssh, 443-https, 80-http, 139-netbios-ssn, 143-imap, 8080-http-proxy.
- The nikto scan results revealed several GET requests methods for target 192.168.56.101 on port 80 (http).

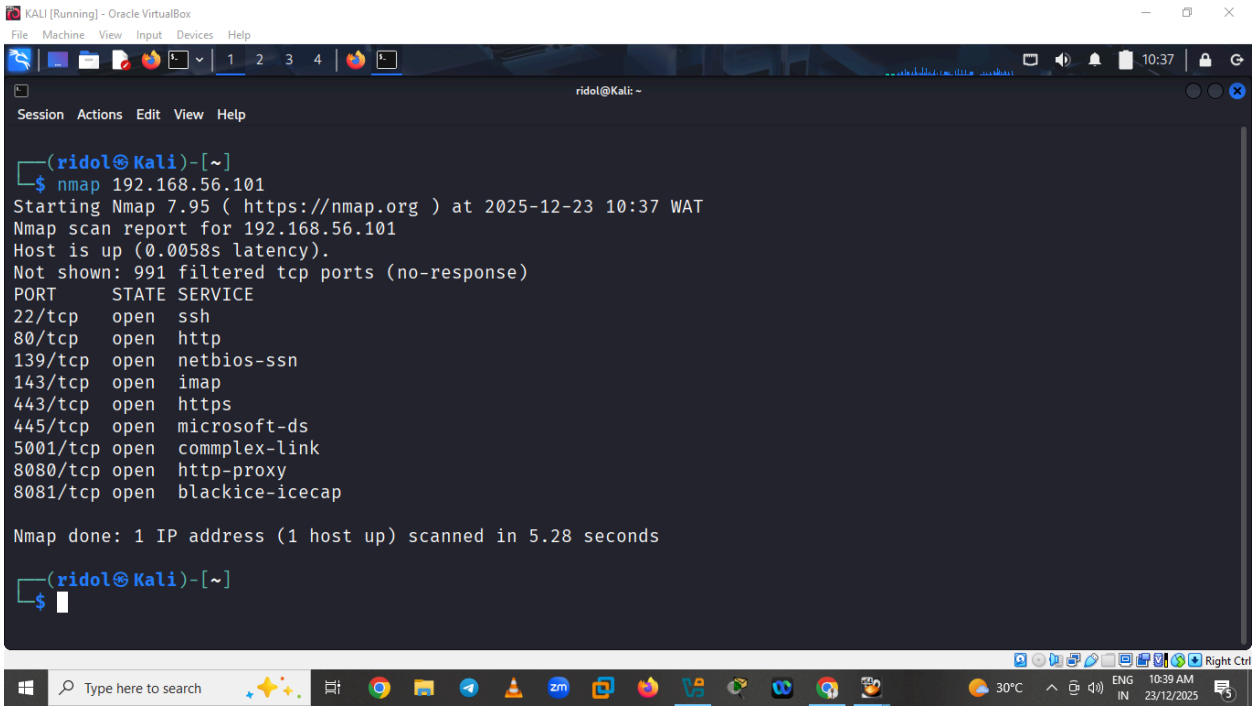

Fig 12: Evidence of linux terminal showing the nmap scan results for the target 192.168.56.101

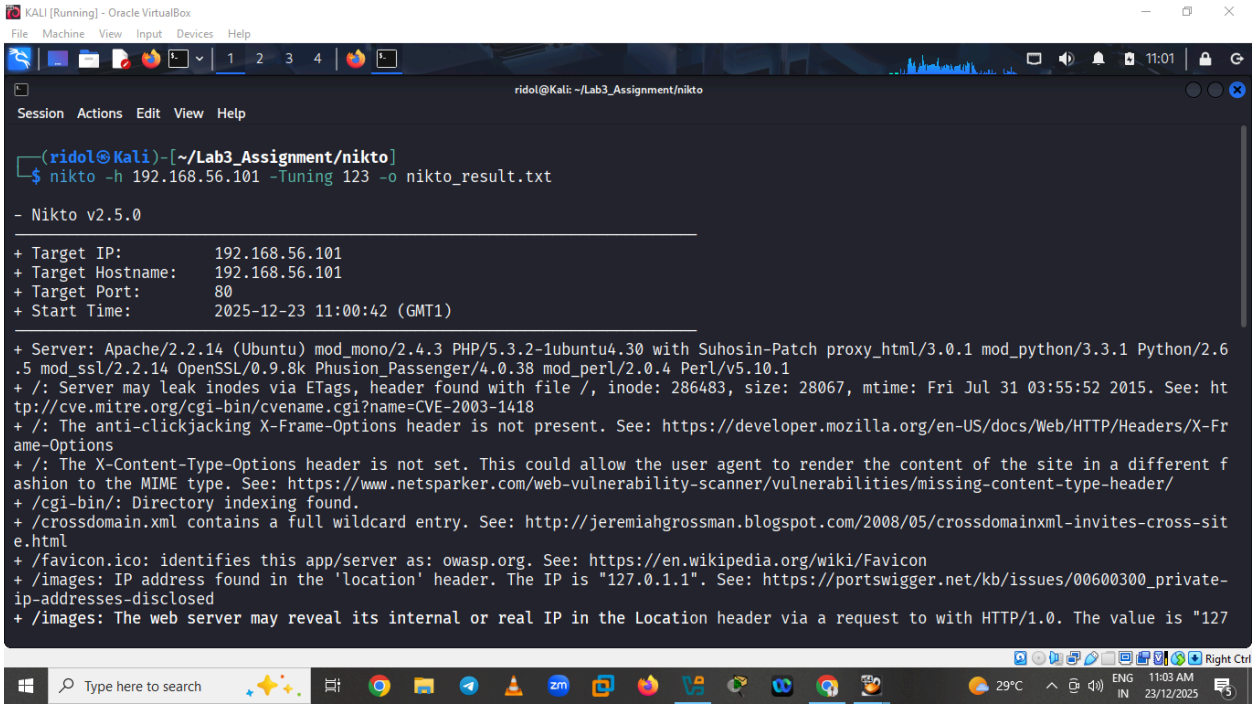

Fig 13: Evidence of linux terminal showing the nikto scan results for the target 192.168.56.101

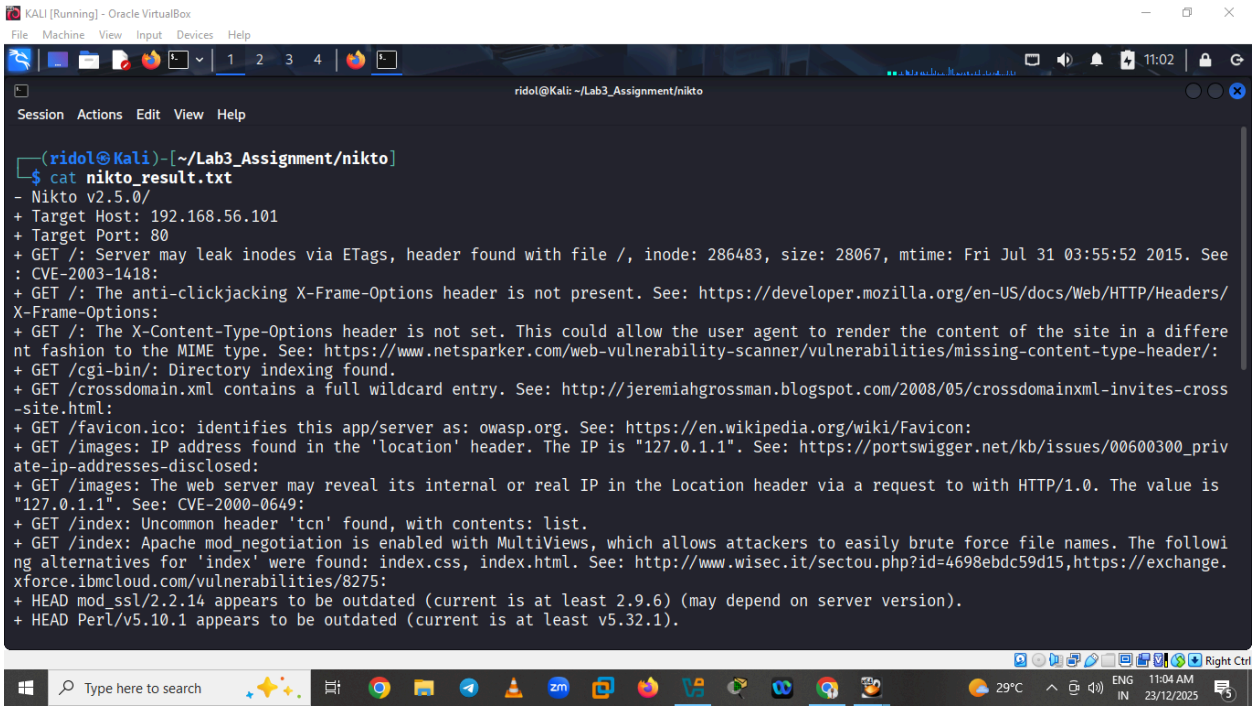

Fig 14: Evidence of linux terminal showing the nikto results .txt file

3.7 Part 7 : Bash scripting for Simple reconnaissance Tool

- Open the Linux terminal and run the following command
- Nano recon_tool.sh && chmod +x recon_tool.sh
- Then the bash script was written in the nano text editor

```
!/bin/bash

echo "By:Ridwan"
echo "================================"
echo " Simple Reconnaissance Tool"
echo "================================"

# Prompt user for target
read -p "Enter target IP address or domain: " target

echo ""
echo "Select a tool to run:"
echo "1) WhatWeb"
echo "2) Nmap"
echo "3) Dirb"
echo "4) KnockPy"
echo ""

read -p "Enter your choice (1-4): " choice

echo ""
```

```
echo "Running scan..."
echo "-------------------------------"

case $choice in
    1)
        echo "[+] Running WhatWeb on $target"
        whatweb "$target"
        ;;
    2)
        echo "[+] Running Nmap on $target"
        nmap "$target"
        ;;
    3)
        echo "[+] Running Dirb on $target"
        dirb "http://$target"
        ;;
    4)
        echo "[+] Running KnockPy on $target"
       source knock-env/bin/activate &&  knockpy -d "$target"
--recon
        ;;
    *)
        echo "[-] Invalid option selected"
        ;;
esac
echo "-------------------------------"
echo "Scan completed."
```

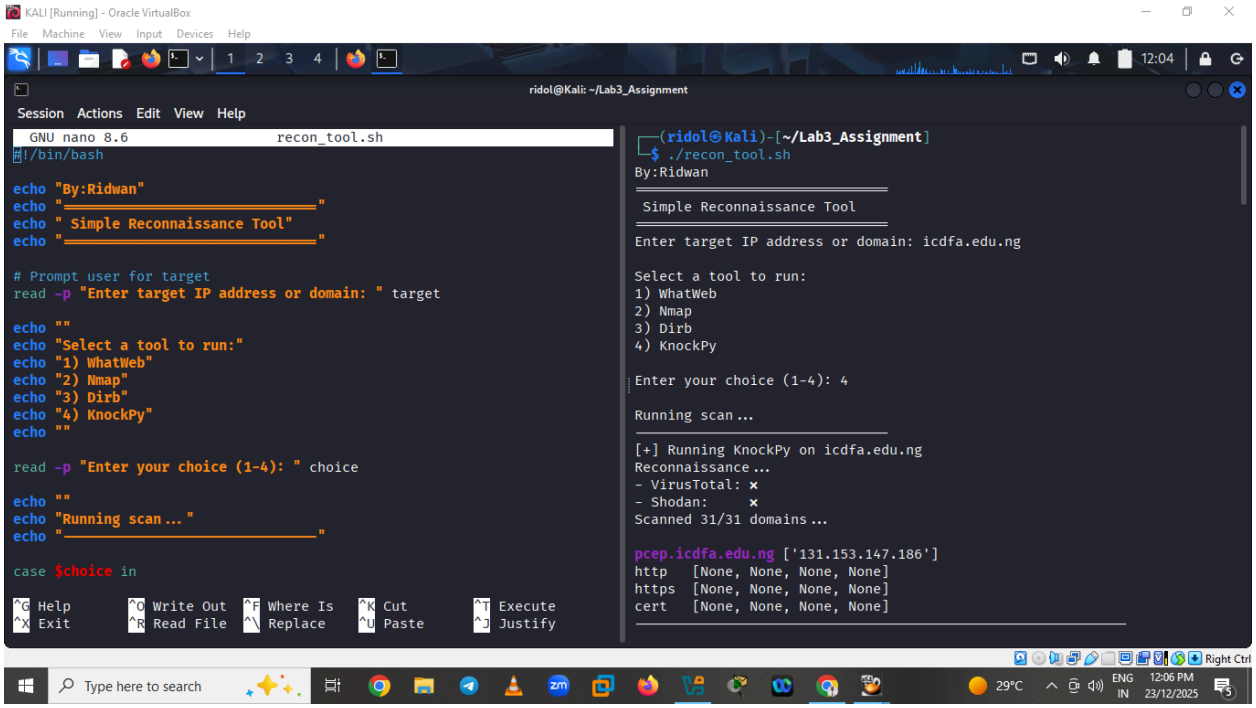

Fig 15: Evidence of nano text editor showing the bash script for recon.sh.

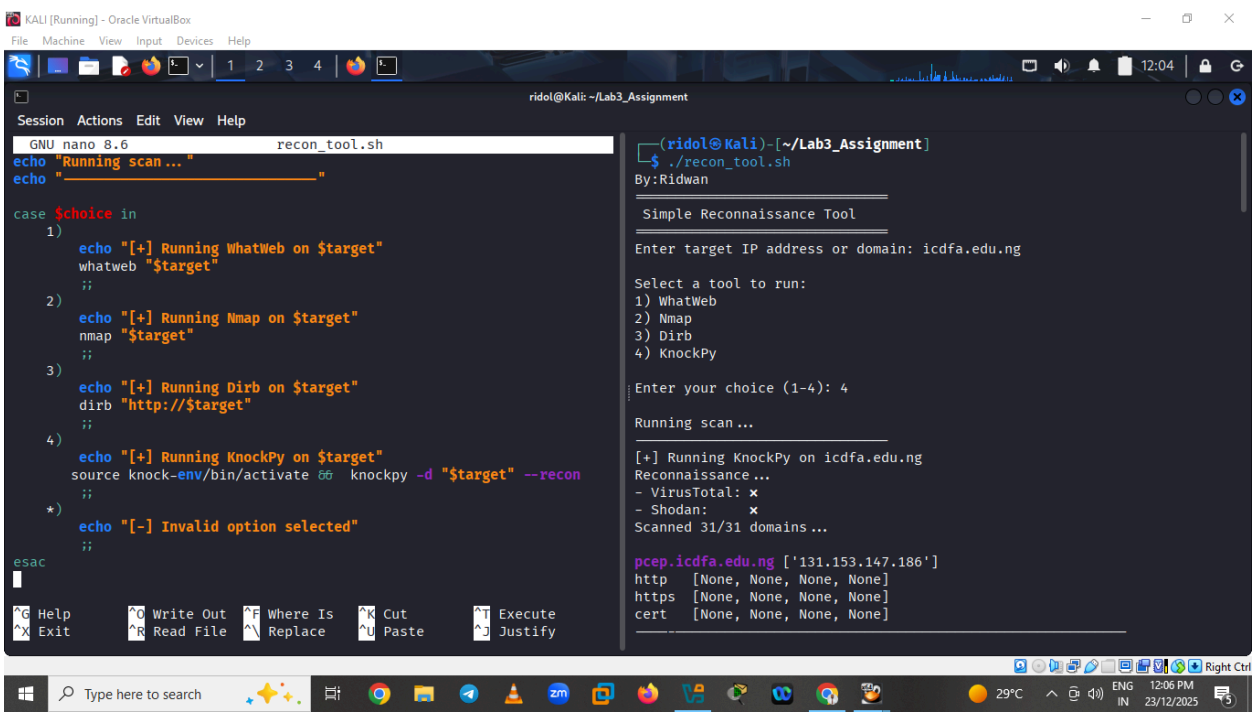

Fig 16: Evidence of nano text editor showing the bash script for recon.sh.

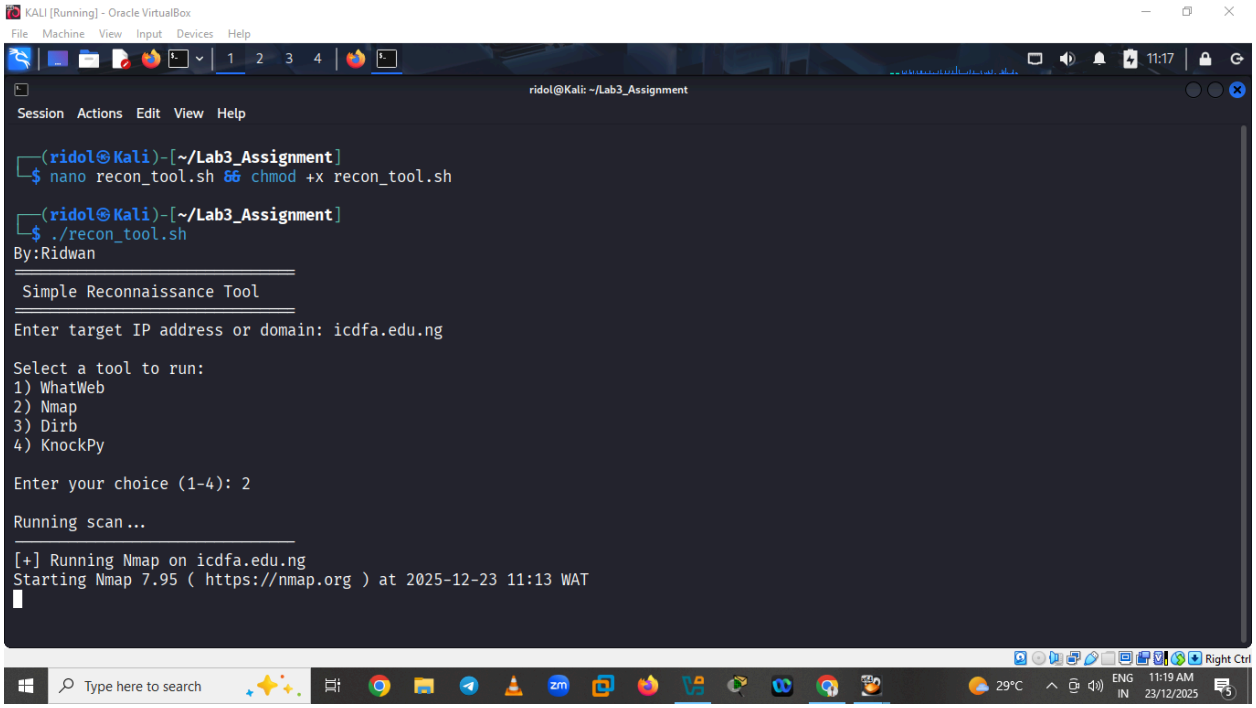

Fig 17: Evidence of Linux terminal showing the bash script execution.

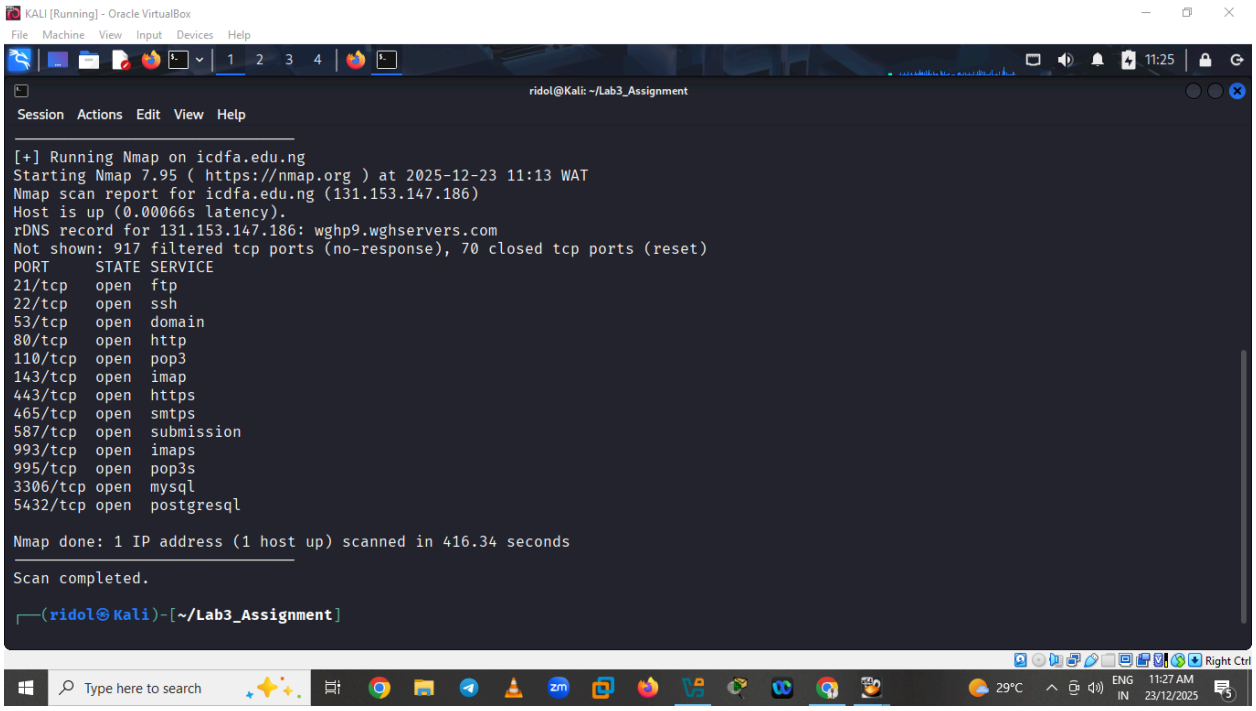

Fig 18: Evidence of Linux terminal showing the bash script execution.

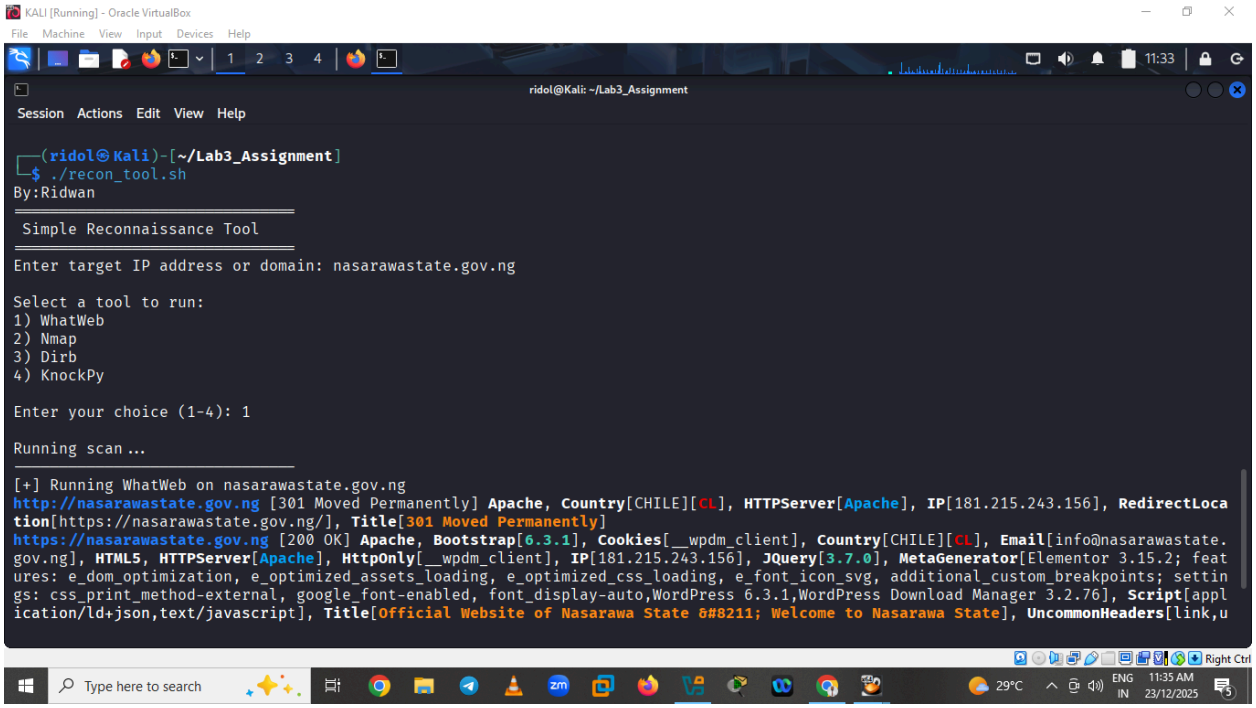

Fig 19: Evidence of Linux terminal showing the bash script execution.

3.8 Part 8

3.8.1 Post Request

A post request is one of the four types of request used in a website, specifically http(s) header.They are used to send and create new data to the web server such as a new user signing up on a website or adding new data on a website to the web server from the client side. It's a request that flows from client side to server side.

3.8.2 Get Request

A get request is almost the opposite of a post request in that they are used to fetch stored data from the web server to the client side. The get requests are also responsible for fetching web pages beyond user data.

3.8.3 A quick case study

A new user signing up on icdfa.edu.ng uses a post request to create and store new data on the server. Upon signing up successfully, the user sends a get request in the process of logging into

the website likewise every other page the user tries to access uses a get request to fetch the web page from icdfa web server.

3.9 Part 9

Information Gathering in Web Application Security

Information gathering also known as reconnaissance plays a vital role in information security most especially penetration testing. In order for an attacker or penetration tester to carry out any form of attack, gathering information about the target is unavoidably the first step. This would assist the attacker to gather, understand and most especially craft their attack around the vulnerability or framework information collected about the target.

Information Security defender also uses information gathered about a malicious visitor on their website to understand a common or regular pattern of certain attack and therefore used that as a base for establishing a defense mechanism that would easily identify or counter such pattern in the future. This is how intrusion detection systems and intrusion prevention systems are built.

3.10 Part 10

3.10.1 How Websites works (request-response model, DNS role)

When a user interacts with a website to perform any action or process, every activity going on on the user side of the interface is known as client-side activities. Client side is where requests such as post, get, put or delete are being initiated. Upon initiation of these requests, the other part of the receiving end is known as server-side, this is where processing and action of the client-side request takes place.

Depending on the type of request initiated from the client-side, the server sends a formatted response with situation code such as 200 (ok) if the request is authenticated and successful and the web browser delivers this response back to the client-side. This forms the request-response model on a website.

3.10.2 Domain Name System (DNS)

When any user tries to access any server such as web server or mail server the internet and websites do not know any server by their usual name or domain name rather by their IP

addresses this is where the DNS comes in. The DNS resolves these common website names to IP addresses already mapped to this unique domain name and is only when a web server can communicate and locate the server being visited by the user.

3.10.3 DNS server

The DNS server acts as a container holding IP addresses mapped to domain names (website names). When user tries to visit a website using a domain name such as www.icdfa.edu.ng, the first journey of the process is routed to a DNS server to resolve/fetch the domain name to an IP address, the IP address is then routed back to the web to visit and only then can the website be located. However resolving a domain name to its IP address does not guarantee successful queries of the website especially if the web server is down. That is completely beyond the responsibility of a DNS server.

4.0 Analysis and Findings

4.1 Results

The knockpy subdomains enumerator revealed more structured and detailed subdomains for the target than the sublist3r tool. Information exposed includes the IP address, TLS version and other cert details.

4.2 Differences

Sublist3r primarily uses **passive reconnaissance techniques**. It collects subdomains from multiple public sources such as search engines, certificate transparency logs, and third-party APIs. Knockpy, in contrast, focuses more on **active enumeration**. It uses a **wordlist-based brute-force approach** combined with DNS resolution to actively test for the existence of subdomains.

5.0 Conclusion and Recommendations

The reconnaissance tools happen to reveal rich information about the target on different levels . This can be attributed to the extent at which they can queries target api and access control level of the target such as firewalls rules.

References

Behl, A., & Behl, K. (2017). Cyberwar: The next threat to national security and what to do about it. Oxford University Press.

Engebretson, P. (2013). The basics of hacking and penetration testing: Ethical hacking and penetration testing made easy (2nd ed.). Syngress.

OWASP Foundation. (2023). OWASP Web Security Testing Guide. https://owasp.org/www-project-web-security-testing-guide/

Stuttard, D., & Pinto, M. (2011). The web application hacker's handbook: Finding and exploiting security flaws (2nd ed.). Wiley.